Pivot and lateral movement in a segmented network

An expert, authorization-first project that runs post-exploitation across a segmented network from a single foothold: route into the segment with Ligolo-ng, listen and relay with Responder, validate and spread credentials with NetExec, pull secrets and abuse tickets with Impacket, take interactive WinRM shells with Evil-WinRM, and drive controlled post-exploitation with Metasploit. It ends where it must: proving the blue team saw each step and remediating the paths that worked. Defensive use only, on your own systems or with written permission.

9 phases | 18 steps | Tick each item when its "done when" criterion is true

Phase 1 Authorize the engagement, fix the segment scope and notify defenders about 1-3 days

- [ ] **1.1 Get written authorization that names the foothold, the segments and the destructive-test boundary**
  A signed or ticketed approval names the assumed-breach foothold, each in-scope subnet/VLAN and host group, the account tiers you may target, the allowed techniques, the date window and a stop-contact
- [ ] **1.2 Notify the SOC and agree what engagement activity looks like**
  SOC has the window, the foothold and assessment source identities, and the expected signals (poisoning, spraying, WinRM sessions, DCSync-style reads) so engagement alerts are triaged, not auto-closed

Phase 2 Establish the pivot into the segment with Ligolo-ng about 0.5-1 day

- [ ] **2.1 Bring up the Ligolo-ng tunnel and route only in-scope subnets**
  The proxy has a TUN interface up, the agent is running on the approved foothold, and routes exist only for subnets named in the scope
- [ ] **2.2 Treat the tunnel as monitored infrastructure and plan teardown**
  Tunnel source, routes and active window are in the engagement log, and a teardown step removes routes and stops the agent at the end of the phase

Phase 3 Listen and (where in scope) relay with Responder about 0.5-1 day

- [ ] **3.1 Run Responder in analyze mode first to measure the exposure**
  Responder has run in a passive/analyze posture on the in-scope segment and the volume of LLMNR/NBT-NS/mDNS requests and responder-visible hosts is recorded
- [ ] **3.2 Capture or relay within scope and feed results to the next phase**
  Captured NetNTLM material is stored as restricted evidence (for offline cracking) or relayed only to in-scope targets that lack signing, with every action logged

Phase 4 Validate and measure credential spread with NetExec about 1-2 days

- [ ] **4.1 Confirm reachability and validate credentials across the in-scope range**
  NetExec has confirmed SMB/LDAP/WinRM reachability for the in-scope subnet and validated each test credential, with results exported for the report
- [ ] **4.2 Map the reachable attack surface with read-only modules before executing**
  Shares, sessions, logged-on users and signing status across the in-scope hosts are enumerated and feed a prioritised target list; no destructive module has run yet

Phase 5 Remote execution, secrets and tickets with Impacket about 1-3 days

- [ ] **5.1 Execute on named hosts with the quietest sufficient Impacket method**
  Any remote execution uses a documented Impacket example tool against a named in-scope host, with the method, host and output recorded
- [ ] **5.2 Extract secrets and abuse tickets only within an explicit clause**
  NTDS/LSA/SAM extraction and Kerberos ticket operations are limited to hosts named in a destructive-test clause, stored as restricted evidence, and logged for the detection phase

Phase 6 Interactive WinRM footholds with Evil-WinRM about 0.5-1 day

- [ ] **6.1 Open an Evil-WinRM session only where WinRM is in scope and reachable**
  An Evil-WinRM session exists against a named in-scope host over WinRM, authenticated with validated credentials or a hash, with the session window logged

Phase 7 Controlled post-exploitation and further pivoting with Metasploit about 1-3 days

- [ ] **7.1 Use Metasploit for session management and scoped modules, not spray-and-pray**
  Any Metasploit module is chosen for a named in-scope host with the module, options and output recorded; payloads and listeners are controlled and removed at close
- [ ] **7.2 Tie the chain into a single lateral-movement narrative**
  The report shows the end-to-end path (foothold → pivot → capture → spread → execute → privilege) with the control that should have broken each link

Phase 8 Prove detection across the lateral-movement chain about 1-2 days

- [ ] **8.1 Correlate identity and endpoint telemetry with the engagement timeline**
  For each active phase the SOC can show matching Defender for Identity / advanced-hunting telemetry or a ticketed detection gap
- [ ] **8.2 Confirm Kerberos and account-control detections fired**
  Kerberoasting/AS-REP patterns, pass-the-hash and ticket-reuse activity are visible in identity telemetry for the test accounts, and gaps are ticketed

Phase 9 Remediate the paths, retest, wipe and close about 1-4 weeks

- [ ] **9.1 Close the controls that should have broken the chain**
  Each headline link has a closed change: segmentation, SMB/LDAP signing, LAPS, tiering, Credential Guard or WinRM restriction, with before/after evidence
- [ ] **9.2 Add the missing detections and retest the headline path**
  Detection-engineering tickets from phase 8 are implemented, and a dated retest shows the critical lateral-movement path broken
- [ ] **9.3 Wipe the loot, remove tooling and schedule the next assessment**
  All engagement data is wiped or vaulted, tunnels/agents/payloads are removed, assessment accounts are disabled, and a retest cadence is booked

Owner	Change / ticket	Date completed

Original checklist by Tenant Recipes, an independent project not affiliated with Microsoft or any vendor. Every step, its actions, pitfalls and the official sources it was checked against are on https://tenantrecipes.com/guides/pivot-lateral-movement-segmented.html. Time estimates are our own planning figures. Confirm against the linked sources and test in a pilot before production.